

Online Shopping System (OSS) Proposal

Introduction

This proposal gives an overview of online shopping systems, hereafter referred to as OSSs. It will analyse the positive aspects and the concerns of these systems. Then it will take an in-depth look at system security, performing threat modelling to determine likely attacks and their mitigations, and integrating the results into the system design to provide assurance. This will show that an OSS is the right move for your company, and that our business is best placed to implement it for you in a secure manner.

OSS Positives

OSSs bring multiple benefits, both to the customer and the owner. For customers, practical benefits include the convenience of shopping from home, alongside easier access to information about products (Zhao et al., 2022). In the context of a grocery shop this allows the possibility to give more detail on produce provenance. For owners a primary benefit is the lower cost involved setting up and running OSS compared to a physical store, with savings in many areas, including rental, equipment and labour costs (Al Tamer, 2021: 2). A further benefit is the ability to manage the customer relationship in a more effective way, with the goal of fostering familiarity and loyalty. This is achieved via improvements to customer service such as product demand analysis, experience personalisation, and easier access to customer support (Parikshith & Natesan, 2023). This can also be optimised using customer relationship management (CRM) tools, which can be set to perform various tasks to maintain customer contact, such as follow-up thank you and quality check emails a set time after purchase (Al Tamer, 2021 :2).

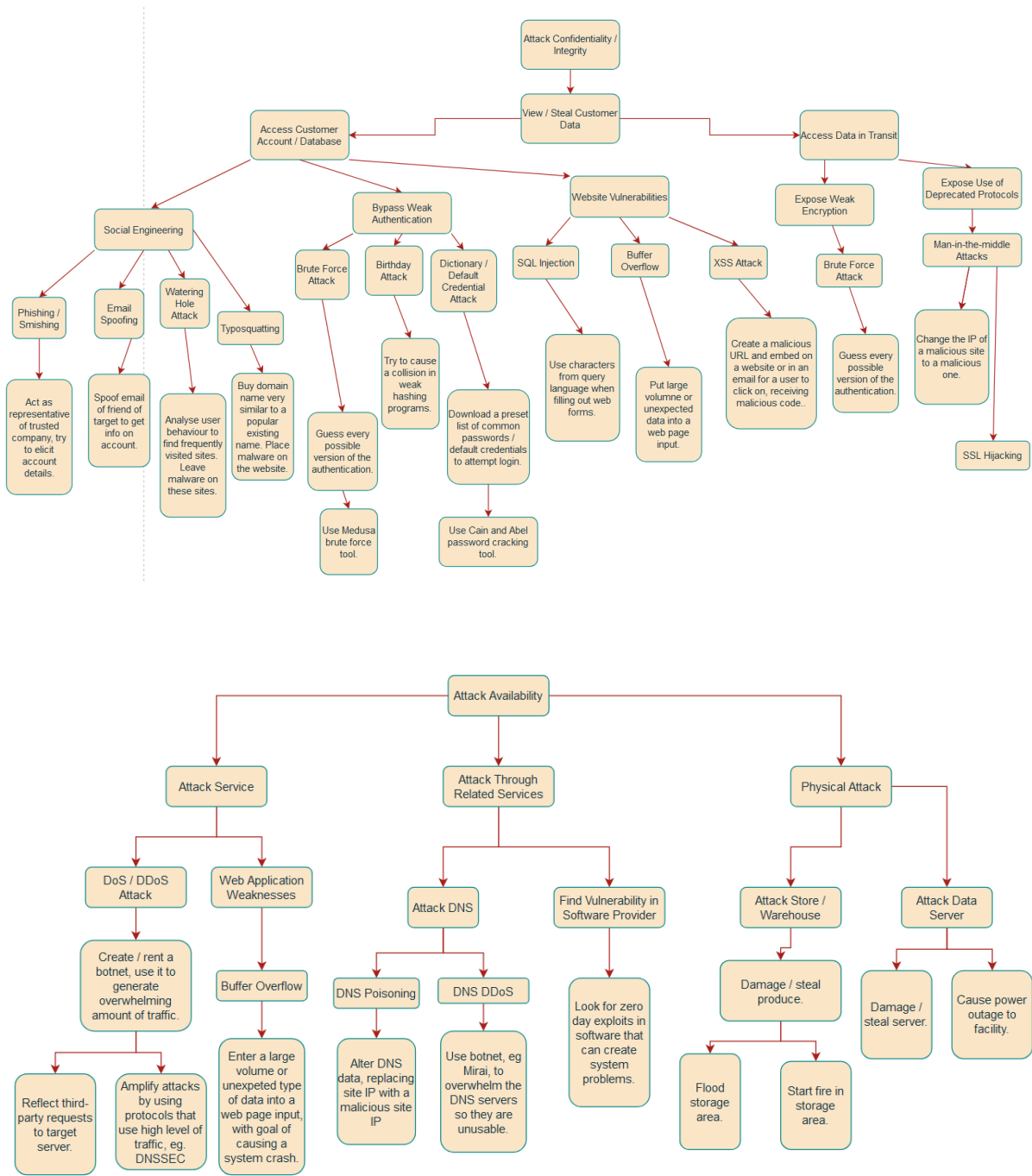
OSS Concerns

There are some concerns with OSSs, these can be split into two categories – concerns over quality control, and concerns over security. Quality control concerns include a lack of physical interaction with the product, thus being unable to guarantee quality control, and delivery times. Security concerns include data breaches and identity theft (Parikshith & Natesan, 2023). Quality control concerns should be handled by staff training and careful selection of vendors and delivery services. Security concerns will be covered in detail in the rest of this proposal.

Threat Model Analysis

The following diagrams are attack tree models that show potential pathways for attacks on the CIA triad. The first attack tree shows potential attacks on confidentiality and

integrity, the second availability.



Sources used: Gibson, D. & Shelley, J. (2023), Jernigan, S., & Meyers, M. (2022), Fortinet (2024), Cloudflare (2024) and Tidmarsh (2023).

Alongside these attack trees, selected threats have been analysed with Stride and Dread threat models. These include mitigations of the threats, and an overall threat score of the specific example of the stride category used in the stride table.

Stride Table

Category	Example Threat	Mitigation
<u>Spoofing</u>	User receives email claiming to be from shop, providing a link to update login info.	Use DMARC to authenticate emails, and MFA to make login more secure (Navqi et al., 2023: 11)
<u>Tampering</u>	Disgruntled employee attempts to modify customer data.	Use DAC permissions so that users can only access data required for their role (Gibson & Shelley, 2023).
<u>Repudiation</u>	Customer claims to have been charged for products they did not order.	Set up an audit log system to track user behaviour (MacDonald, 2016).
<u>Information Disclosure</u>	Attacker enters system and accesses customer cardholder data.	Only some card data is stored, sensitive data, such as CVVs and PINs are not (Anderson, 2020: 401).
<u>Denial of Service (DoS)</u>	A botnet floods the service with traffic.	Filtering of network traffic and rate limiting (Dayal & Srivastava, 2023: 3)
<u>Elevation of Privilege</u>	A user attempts a SQLi attack to gain admin privilege by putting malicious input into the query function.	Use input validation on setup (Gibson and Shelley, 2023)

Dread Table

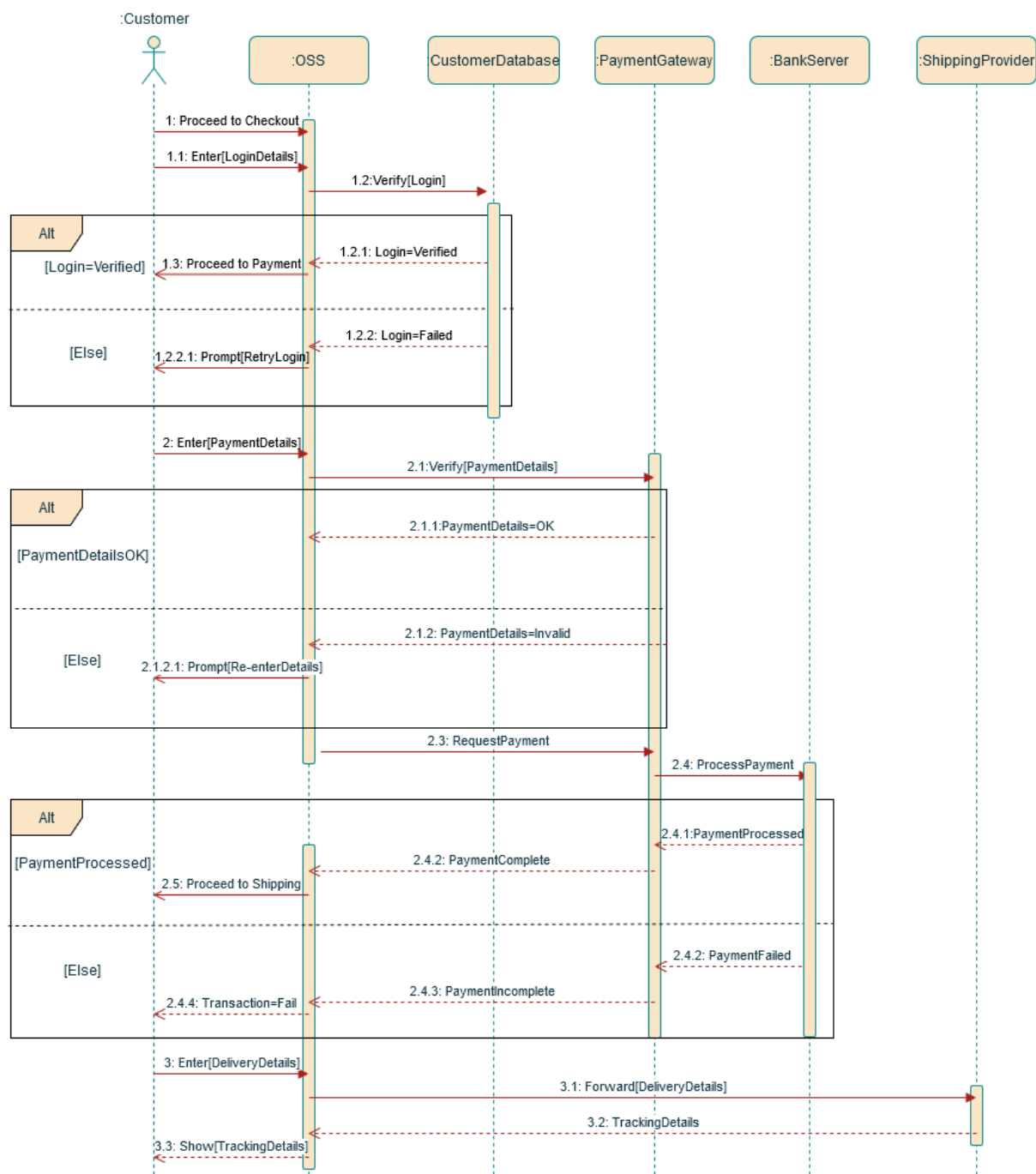
Threat (0-10)	Damage	Reproducibility	Exploitability	Affected Users	Discoverability	Score
<u>Spoofing</u>	6	10	8	6	10	40
<u>Tampering</u>	9	5	3	9	3	29
<u>Repudiation</u>	3	3	2	2	3	13
<u>Information Disclosure</u>	9	4	5	10	4	32
<u>Denial of Service (DoS)</u>	10	8	9	10	7	44
<u>Elevation of Privilege</u>	10	3	5	8	3	29

From our dread model ratings DoS attacks are rated as the primary issue, followed by spoofing and information disclosure.

UML Sequence Diagram Analysis

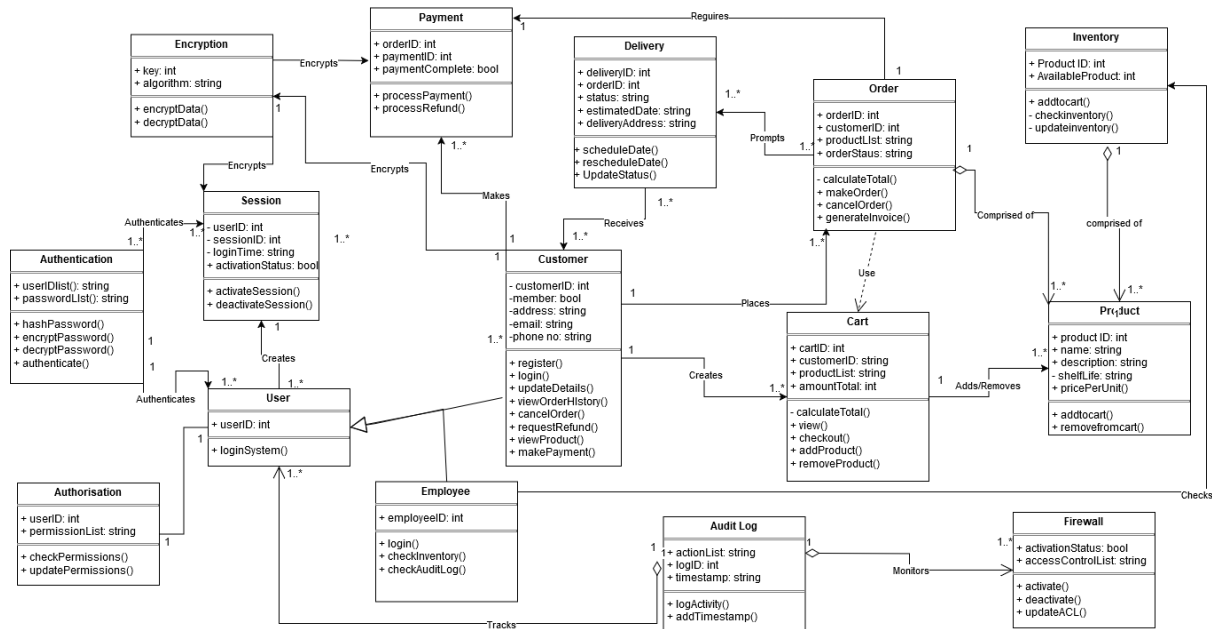
One general area of concern in online shopping is the security at checkout. Below is a UML sequence diagram showing a general checkout experience. We can use the information gained from the threat modelling to improve the security of the process.

At points 1.1 and 1.2 we can add MFA to the login process, in case of malicious actors having access to our login details. At all points the data is in transit we should be using some form of encryption to protect it, but not deprecated protocols like SSL. Instead, we should use TLS alongside HTTPS. The details in the customer database should also be encrypted. At points 2.4.2 and 3.3 we could make use of a CRM system mentioned above to send emails confirming purchase and providing a link to track delivery. It is important to setup DMARC to prevent spoofing.



UML Class Diagram

The final diagram is a class diagram denoting the relationships in an example environment and the basis of our company's proposed design for the future OSS of your business.



It encompasses all the regular classes that exist in a grocery OSS and includes security measures that work to protect against the attacks detailed in the threat models. This includes authentication to protect against spoofing, authorisation to protect against tampering, an audit log class to guard against repudiation, and encryption to stop information disclosure. Input validation would need to be added at the implementation phase of the OSS. The firewall has multiple functions; it can stop intrusions but also guard against DoS / DDoS attacks by monitoring packets.

This diagram has been constructed with PCI DSS compliance as a consideration. Of the 12 requirements of the standards, 8 would be met by the implementation of the class diagram above, with the remaining 4 needing to be considered at a later phase (PCI Security Standards Council, 2015 :9).

Conclusion

In conclusion, OSSs have a multitude of benefits that will allow your grocery business to continue developing. There are concerns: quality control and security. Quality control is addressed by staff training and prudent selection of vendors, good business practices whether online or offline. Security concerns exist, but through integrating security technologies into the design these factors can be mitigated and security regulations abided by.

References:

Al Tamer, M. (2021) THE ADVANTAGES AND LIMITATIONS OF E-COMMERCE TO BOTH CUSTOMERS & BUSINESSES. *BAU Journal – Creative Sustainable Development* 2(2). DOI: <https://doi.org/10.54729/2789-8334.1043>.

Anderson, R. (2020) *Security Engineering: A Guide to Building Dependable Distributed Systems*. 3rd ed. Indianapolis, Indiana: John Wiley & Sons, Inc.

Cloudflare (2024) What is a DNS flood? | DNS flood DDoS attack. Available from: <https://www.cloudflare.com/learning/ddos/dns-flood-ddos-attack/> [Accessed 22 December 2024].

Dayal, N. & Srivastava, S. (2023) Analyzing effective mitigation of DDoS attack with software defined networking. *Computers & Security* 130. DOI: <https://doi.org/10.1016/j.cose.2023.103269>.

Fortinet (2024) Man-in-the-Middle Attack: Types and Examples. Available from: <https://www.fortinet.com/it/resources/cyberglossary/man-in-the-middle-attack> [Accessed 22 December 2024].

Gibson, D. & Shelley, J. (2023) *CompTIA Security+: Get Certified Get Ahead SYO-701 Study Guide*. United States: Certification Experts LLC.

Jernigan, S., & Meyers, M. (2022) *Mike Meyers' CompTIA Network+ Guide to Managing and Troubleshooting Networks, Sixth Edition (Exam N10-008), 6th Edition*. New York, New York: McGraw-Hill.

MacDonald, K. (2016) The Security Benefits of Audit Logging. Available from: <https://www.digicert.com/blog/the-security-benefits-of-audit-logging> [Accessed 23 December 2024].

Navqi et al. (2023) Mitigation strategies against the phishing attacks: A systematic literature review. *Computers and Security* 132. DOI: <https://doi.org/10.1016/j.cose.2023.103387>.

Parikshith, G. & Natesan, G. (2023). Exploring the Benefits of E-commerce Applications for Efficient Online Operations. *International Journal of Scientific Research in Computer Science, Engineering and Information Technology* 10(2): 158-162. DOI: <https://10.32628/CSEIT2390212>.

PCI Security Standards Council. (2015) PCI DSS Quick Reference Guide. Available from: https://listings.pcisecuritystandards.org/documents/PCIDSS_QRGv3_1.pdf [Accessed 23 December 2024].

Seidl, M. et al. (2015) *UML @ Classroom: An Introduction to Object-Orientated Modeling*. Springer International Publishing AG.

Tidmarsh, D. (2023) 100 Top Hacking Tools and Ethical Hacking Tools. Available from: <https://www.eccouncil.org/cybersecurity-exchange/ethical-hacking/best-ethical-hacking-tools/> [Accessed 22 December 2024].

Zhao Y, Zhao X, Liu Y. (2023) Exploring the Impact of Online and Offline Channel Advantages on Brand Relationship Performance: The Mediating Role of Consumer Perceived Value. *Behavioural Sciences* 13(1):16. DOI: <https://10.3390/bs13010016>.